

Engenharia Social

Nome: Gabriel Domingues Silva ***Turma:*** 25E1-2

Tema: TP2

PROF. FABIO CAMPOS CHAVES
Instituto Infnet

Conteúdo

1	Explique o conceito de OSINT passivo e OSINT ativo. Dê exemplos práticos do uso de cada abordagem e discuta os riscos éticos e legais associados a elas.	3
1.1	OSINT Passivo	4
1.2	OSINT Ativo	4
1.3	Riscos Éticos e Legais	4
2	Qual é o papel da modelagem de comunicação na engenharia social? Descreva um exemplo em que adaptar seu estilo de comunicação foi essencial para a construção de rapport com o alvo.	5
2.1	Importância da Modelagem de Comunicação	5
2.2	Exemplo Prático: Construção de Rapport em um Ataque de Pretexting	5
3	Descreva o ciclo OSINT (Coleta, Processamento, Análise, Disseminação) e explique a importância de cada etapa para o sucesso da coleta de dados em engenharia social.	6
3.1	Coleta	6
3.2	Processamento	7
3.3	Análise	7
3.4	Disseminação	7
4	Compare as ferramentas Recon-ng, theHarvester e Maltego. Em quais contextos cada uma delas é mais eficiente na coleta de informações? Cite pelo menos dois exemplos de uso.	8
4.1	Comparação entre as ferramentas	8
4.2	Conclusão	9
5	Discuta os dilemas éticos envolvidos na análise de redes sociais em investigações OSINT. Como garantir o equilíbrio entre segurança e privacidade?	9
5.1	Principais dilemas éticos	9
5.2	Como garantir o equilíbrio entre segurança e privacidade	9
5.3	Conclusão	10
6	Estudo de Caso: Investigação de E-mail Suspeito com Anexo PDF	10
6.1	Coleta de Informações	10
6.2	Processamento	11
6.3	Análise	11
6.4	Disseminação	11
6.5	Ferramentas recomendadas	11
7	Estudo de Caso: Vazamento de Informação Confidencial por Foto em Rede Social	12
7.1	Plano de Mitigação	12
7.2	Proposta de Treinamento de Conscientização em Segurança	12
7.2.1	Conteúdo programático:	12
7.2.2	Materiais de apoio:	13

8	Estudo de Caso: Construção de Perfil Digital de um Executivo com Fontes Abertas	13
8.1	Preparação e Definição de Objetivos	13
8.2	Etapas da Investigação com Fontes Abertas	13
8.2.1	Coleta de dados pessoais e profissionais	13
8.2.2	Mapeamento de presença digital e redes sociais	14
8.2.3	Rotinas e hábitos	14
8.2.4	Dispositivos e aspectos técnicos	14
8.3	Análise e Identificação de Vulnerabilidades	15
8.4	Considerações Éticas	15
9	Estudo de Caso: Exposição Técnica em Anúncios de Emprego Antigos	15
9.1	Análise da Exposição Técnica	15
9.1.1	Exemplos comuns de informações expostas em anúncios	15
9.1.2	Fontes utilizadas na auditoria	16
9.2	Riscos Associados à Exposição	16
9.2.1	Mapeamento de superfície de ataque facilitado	16
9.2.2	Engenharia social mais eficaz	16
9.2.3	Reconhecimento técnico automatizado	16
9.3	Medidas de Mitigação	16
9.3.1	Redação cuidadosa de vagas	16
9.3.2	Revisão periódica de exposições passadas	16
9.3.3	Treinamento e sensibilização do RH e marketing	16
10	Estudo de caso: empresaXYZ.com	17
10.1	WHOIS	17
10.2	Shodan	17
10.3	Hunter.io	17
10.4	LinkedIn	18
10.5	Spear Phishing	18
10.6	Pretexting (Pretexto)	18
10.7	3. Vishing (Phishing por telefone)	18
10.8	Baiting	18
10.9	Watering Hole	18

Questões Discursivas

- 1 Explique o conceito de OSINT passivo e OSINT ativo. Dê exemplos práticos do uso de cada abordagem e discuta os riscos éticos e legais associados a elas.**

OSINT (Open Source Intelligence) é o processo de coleta e análise de informações disponíveis publicamente para gerar inteligência útil. Essas informações podem ser obtidas de fontes como redes sociais, sites, fóruns, bancos de dados públicos, entre outros.

1.1 OSINT Passivo

Definição: O OSINT passivo consiste na coleta de dados **sem interação direta** com o alvo. Isso significa que as atividades realizadas não geram logs nos servidores do alvo e, portanto, são mais discretas.

Exemplos práticos:

- Consultar o **Wayback Machine** (web.archive.org) para acessar versões antigas de sites.
- Utilizar **Google Dorks** para encontrar arquivos públicos em servidores mal configurados.
- Buscar informações de domínios usando o **crt.sh** para identificar certificados SSL registrados.
- Explorar perfis em redes sociais de forma anônima (sem login ou com contas falsas).

Vantagens:

- Baixo risco de detecção.
- Legalidade geralmente preservada.
- Útil para investigação preliminar ou reconhecimento silencioso.

1.2 OSINT Ativo

Definição: O OSINT ativo envolve ações que interagem com o alvo, podendo gerar logs e alertas. Embora ainda se baseie em fontes abertas, a coleta ativa pode levantar suspeitas ou ser rastreada.

Exemplos práticos:

- Realizar consultas **WHOIS** diretamente em servidores de registro para obter dados de domínio.
- Usar ferramentas como **theHarvester** para extrair e-mails e metadados diretamente de servidores.
- Enviar requisições a APIs públicas de serviços para obter informações detalhadas (como Shodan ou Hunter.io).
- Interagir com perfis ou páginas para induzir uma resposta (ex: engenharia social indireta).

Vantagens:

- Pode revelar informações não acessíveis via OSINT passivo.
- Aproxima o analista de um mapeamento mais completo da superfície de ataque.

1.3 Riscos Éticos e Legais

Riscos Éticos:

- Violação da **privacidade** de indivíduos ou empresas, mesmo com uso de fontes públicas.
- Manipulação de pessoas ou dados com finalidades questionáveis (engenharia social maliciosa).
- Coleta excessiva de informações que não têm relevância ou proporcionalidade com o objetivo da análise.

Riscos Legais:

- Dependendo da jurisdição, acessar dados públicos com finalidades específicas (como stalking ou extorsão) pode ser crime.
- Realizar OSINT ativo sem autorização prévia pode ser interpretado como **atividade suspeita ou intrusiva**, violando termos de uso de serviços.
- Compartilhamento indevido de dados sensíveis pode infringir legislações como a **LGPD** (Brasil) ou **GDPR** (Europa).

2 Qual é o papel da modelagem de comunicação na engenharia social? Descreva um exemplo em que adaptar seu estilo de comunicação foi essencial para a construção de rapport com o alvo.

Modelagem de comunicação refere-se à prática de adaptar conscientemente o estilo, o tom, a linguagem corporal e os padrões linguísticos para refletir ou complementar os do interlocutor. Na engenharia social, essa técnica é crucial para estabelecer **rapport**, ou seja, uma relação de empatia e confiança — com o alvo, aumentando significativamente as chances de sucesso na manipulação ou extração de informações.

2.1 Importância da Modelagem de Comunicação

A modelagem é baseada em princípios da **Programação Neurolinguística (PNL)** e envolve diversas dimensões:

- **Tom de voz:** adaptar o volume, ritmo e entonação ao estilo do alvo.
- **Vocabulário:** utilizar termos, gírias ou expressões semelhantes às que o alvo costuma usar.
- **Postura corporal:** espelhar a linguagem corporal do interlocutor para criar familiaridade subconsciente.
- **Formato da comunicação:** se o alvo prefere mensagens diretas, objetivas ou conversas mais informais e abertas.

Benefícios da modelagem na engenharia social:

- Aumenta a percepção de similaridade entre atacante e alvo.
- Reduz resistências e desconfianças iniciais.
- Cria um ambiente mais propício à revelação de informações confidenciais.

2.2 Exemplo Prático: Construção de Rapport em um Ataque de Pretexting

Contexto: Um engenheiro social precisava obter informações sobre a estrutura de TI de uma empresa. O alvo era um funcionário do setor de help desk, conhecido por ser direto, técnico e com pouco tempo disponível para conversas longas.

Adaptação do estilo de comunicação:

- O atacante utilizou um **pretexto corporativo** (se passando por um técnico da matriz).
- Utilizou **jargões técnicos e linguagem objetiva**, demonstrando familiaridade com os sistemas da empresa.
- Manteve a comunicação **rápida e assertiva**, respeitando o estilo do alvo.
- Demonstrou urgência de forma realista: “Estamos tentando mitigar uma falha na replicação da Active Directory, e precisamos confirmar as permissões do grupo de suporte local.”

Resultado:

- O alvo confiou na comunicação devido à familiaridade do vocabulário.
- Compartilhou informações sensíveis sem questionar a legitimidade do interlocutor.
- A operação foi bem-sucedida, graças à adaptação do estilo de comunicação ao perfil técnico do funcionário.

3 Descreva o ciclo OSINT (Coleta, Processamento, Análise, Disseminação) e explique a importância de cada etapa para o sucesso da coleta de dados em engenharia social.

O ciclo OSINT é uma metodologia estruturada utilizada para transformar dados públicos em inteligência acionável. Ele é composto por quatro fases principais:

Coleta → Processamento → Análise → Disseminação

3.1 Coleta

Objetivo: Obter informações a partir de **fontes abertas e acessíveis ao público**.

Fontes típicas:

- Redes sociais (Facebook, LinkedIn, Twitter, etc.)
- Sites institucionais e blogs
- Repositórios de código (GitHub, GitLab)
- Bancos de dados públicos (WHOIS, registros DNS, pastebins)
- Ferramentas automatizadas (Maltego, SpiderFoot, theHarvester, etc.)

Importância:

- É a base de todo o processo. Sem uma coleta eficaz e focada, as etapas seguintes se tornam frágeis ou improdutivas.
- Um erro comum é coletar dados demais e irrelevantes, o que dificulta as próximas fases.

3.2 Processamento

Objetivo: Transformar dados brutos em informações utilizáveis e organizadas.

Ações comuns:

- Filtrar duplicatas ou dados irrelevantes.
- Classificar e categorizar informações.
- Identificar correlações ou cruzamentos de dados (ex: vincular um e-mail a um perfil de rede social).
- Normalizar diferentes formatos (JSON, HTML, texto puro, etc.).

Importância:

- Garante que apenas dados relevantes e precisos avancem para a fase de análise.
- Evita desperdício de tempo com informações redundantes ou desorganizadas.

3.3 Análise

Objetivo: Interpretar as informações processadas para gerar inteligência útil.

Ações típicas:

- Descobrir padrões, comportamentos e relações ocultas.
- Avaliar o valor e a confiabilidade da informação.
- Criar perfis de alvos, identificar vulnerabilidades humanas ou técnicas.

Importância:

- Permite gerar insights estratégicos que podem ser usados para ataques de engenharia social altamente direcionados.
- Uma boa análise transforma dados desconexos em narrativas coerentes que facilitam a tomada de decisão.

3.4 Disseminação

Objetivo: Compartilhar os resultados da análise com as partes interessadas (seja um cliente, equipe interna ou outro operador).

Formatos comuns:

- Relatórios técnicos ou executivos.
- Gráficos, mapas mentais ou infográficos de conexões.
- Dashboards interativos.

Importância:

- Garante que a inteligência produzida seja compreensível e acionável.
- Uma disseminação mal feita compromete toda a operação, mesmo com excelente coleta e análise.

4 Compare as ferramentas Recon-ng, theHarvester e Maltego. Em quais contextos cada uma delas é mais eficiente na coleta de informações? Cite pelo menos dois exemplos de uso.

4.1 Comparação entre as ferramentas

As ferramentas **Recon-ng**, **theHarvester** e **Maltego** são amplamente utilizadas em operações de OSINT, cada uma com suas características, forças e casos de uso ideais. Abaixo, apresentamos uma tabela comparativa detalhada entre elas:

Característica	Recon-ng	theHarvester	Maltego
Tipo de interface	Linha de comando com estrutura modular	Linha de comando simples e direta	Interface gráfica interativa (drag and drop)
Facilidade de uso	Médio: requer familiaridade com linha de comando e módulos	Alto: simples e fácil de executar	Alto: muito visual, ideal para análise de conexões
Foco principal	Coleta modular de dados de domínio, IP, e-mails, etc.	Coleta rápida de e-mails e subdomínios	Mapeamento visual de redes sociais, infraestrutura e conexões entre entidades
Fontes de dados	APIs externas (Shodan, WhoisXML, etc.), DNS, registros públicos	Motores de busca, DNS, LinkedIn, PGP, Shodan	Integrações com diversas fontes (Transformações Paterva, APIs externas, bancos de dados OSINT)
Contextos ideais	Investigações técnicas automatizadas em escala, como enumeração de subdomínios	Coletas rápidas em fases iniciais de um pentest ou investigação	Análise de conexões entre pessoas, empresas, domínios e IPs de forma visual
Exemplo de uso 1	Enumerar subdomínios e e-mails de uma organização usando APIs e salvar em banco de dados interno	Buscar e-mails públicos associados a um domínio (ex: @empresa.com)	Investigar relações entre pessoas em redes sociais e identificar alvos secundários
Exemplo de uso 2	Automatizar a coleta de WHOIS, DNS reverso, certificados SSL de um domínio-alvo	Identificar possíveis pontos de entrada em campanhas de spear phishing	Mapear infraestrutura digital de uma empresa com visualização gráfica de ativos

Tabela 1: Comparação entre Recon-ng, theHarvester e Maltego

4.2 Conclusão

- **Recon-ng** é ideal para automação e investigações técnicas profundas com base em domínio/IP.
- **theHarvester** destaca-se pela simplicidade e velocidade, útil para coletas iniciais.
- **Maltego** é poderoso para investigações visuais complexas, especialmente quando é necessário entender redes de relacionamentos.
- A escolha da ferramenta depende do **objetivo da investigação**, do **tempo disponível** e da **profundidade exigida**.

5 Discuta os dilemas éticos envolvidos na análise de redes sociais em investigações OSINT. Como garantir o equilíbrio entre segurança e privacidade?

A análise de redes sociais é uma etapa poderosa e sensível nas investigações OSINT, pois permite acessar uma quantidade imensa de dados pessoais — muitas vezes fornecidos voluntariamente pelos próprios usuários. No entanto, o uso dessas informações levanta diversos **dilemas éticos** que precisam ser considerados, especialmente quando se busca equilibrar **segurança** e **privacidade**.

5.1 Principais dilemas éticos

- **Consentimento implícito vs. explícito:** Embora os dados estejam disponíveis publicamente, os usuários nem sempre têm consciência de que essas informações podem ser usadas em investigações. A fronteira entre o que é “público” e o que é “ético” nem sempre é clara.
- **Exposição de terceiros:** Em muitos casos, ao investigar um alvo, expõe-se também seus contatos, amigos, familiares e colegas, que não estão envolvidos diretamente no caso.
- **Viés na interpretação:** Postagens e interações em redes sociais podem ser mal interpretadas fora de contexto, levando a conclusões equivocadas sobre a intenção, comportamento ou ideologia de um indivíduo.
- **Uso indevido da informação:** Informações coletadas eticamente podem ser reutilizadas em contextos maliciosos, como campanhas de desinformação, engenharia social ou extorsão.

5.2 Como garantir o equilíbrio entre segurança e privacidade

- **Definir escopos claros de investigação:** Antes de iniciar qualquer coleta, delimite o objetivo e os limites do trabalho. Investigações sem foco tendem a violar a privacidade desnecessariamente.
- **Respeitar a finalidade da coleta:** Use os dados apenas para o propósito definido inicialmente, evitando reutilização para outros fins não autorizados.
- **Aplicar princípios de minimização de dados:** Colete apenas as informações necessárias. Evite armazenar ou divulgar dados sensíveis que não estejam diretamente relacionados ao objetivo da investigação.

- **Avaliar o risco de dano:** Considere se a divulgação ou uso da informação pode gerar prejuízo à reputação, segurança ou dignidade das pessoas envolvidas.
- **Buscar anonimização sempre que possível:** Em relatórios e disseminações, remova identificadores pessoais que não sejam essenciais para a análise.
- **Estar em conformidade com leis e diretrizes:** Respeite legislações de proteção de dados, como a **LGPD (Brasil)** ou o **GDPR (Europa)**, e normas internas de conduta.

5.3 Conclusão

A ética na análise de redes sociais com OSINT é tão importante quanto a técnica. Um investigador responsável deve sempre ponderar:

“Tenho o direito de acessar isso? Tenho o dever de usar isso?”

Ao aplicar princípios éticos e boas práticas, é possível alcançar um equilíbrio saudável entre **a necessidade de segurança e o respeito à privacidade individual**, promovendo investigações eficazes e socialmente responsáveis.

Estudos de Caso (Relatórios)

6 Estudo de Caso: Investigação de E-mail Suspeito com Anexo PDF

Neste estudo de caso, aplicaremos o ciclo OSINT (Coleta, Processamento, Análise, Disseminação) para investigar a origem de um e-mail suspeito com anexo em PDF, recebido por uma empresa. O objetivo é identificar possíveis sinais de ataque, tais como phishing, malware ou engenharia social.

6.1 Coleta de Informações

Etapas da coleta:

- **Cabeçalho do e-mail:** Extração do cabeçalho completo (*email header*) para obter informações como:
 - IP do remetente
 - Servidores de e-mail utilizados
 - SPF, DKIM, DMARC (autenticações do domínio)
 - Data, hora e ID da mensagem
- **Anexo em PDF:**
 - Hash do arquivo (MD5, SHA-1, SHA-256)
 - Extração de metadados do PDF (autor, software utilizado, data de criação)
 - Extração de URLs, scripts embutidos ou links maliciosos
- **Domínio e e-mail do remetente:**
 - Whois do domínio
 - Reputação do domínio (via VirusTotal, AbuseIPDB, etc.)
 - Presença em bancos de dados de phishing

6.2 Processamento

Organização dos dados coletados:

- Normalização do IP e localização geográfica do servidor.
- Cruzamento de dados do domínio com histórico de abusos e criação recente.
- Isolamento do anexo PDF em ambiente seguro (sandbox) para análise estática e dinâmica.
- Extração dos artefatos relevantes do PDF e do conteúdo textual do e-mail.

6.3 Análise

Possíveis indicadores de ataque identificados:

- **IP suspeito:** IP de envio com má reputação ou listado em blacklists.
- **Domínio novo ou recém-registrado:** Domínios criados há poucos dias são comuns em campanhas de phishing.
- **Falsificação de identidade (spoofing):** Falhas em SPF ou DKIM podem indicar que o e-mail foi enviado em nome de outro domínio.
- **Anexo malicioso:** PDF contendo *JavaScript* ou links para páginas de phishing.
- **Engenharia social no conteúdo:** Linguagem urgente ou alarmante, tentando induzir o clique no anexo.

6.4 Disseminação

Elaboração de relatório técnico com:

- Cronologia da investigação
- Capturas de tela e logs das ferramentas utilizadas
- Indicadores de comprometimento (IOCs)
- Recomendação de bloqueio do domínio/IP e alerta à equipe de segurança
- Sugestões para conscientização interna e revisão de filtros de e-mail

6.5 Ferramentas recomendadas

- VirusTotal, URLscan.io, Hybrid Analysis (para análise do PDF)
- MXToolbox, Mail Header Analyzer (para análise do cabeçalho do e-mail)
- Whois, DNSDumpster, theHarvester (para análise do domínio)
- Maltego (para visualizar conexões entre remetente, domínio, IP, arquivos)

7 Estudo de Caso: Vazamento de Informação Confidencial por Foto em Rede Social

Neste estudo de caso, um colaborador publicou fotos do escritório no Instagram e, inadvertidamente, revelou um documento confidencial visível no fundo da imagem. Esse incidente é um exemplo clássico de **vazamento de dados por engenharia social visual** (Visual Hacking), e exige ações imediatas de mitigação e conscientização.

7.1 Plano de Mitigação

Ações imediatas:

- **Identificação da publicação:** Captura da imagem e verificação da presença de documentos, telas de computador, quadros brancos ou outras informações sensíveis.
- **Solicitação de remoção:** Contato com o colaborador solicitando a exclusão imediata da publicação, incluindo fotos em Stories, Reels ou qualquer outro formato visível.
- **Análise de impacto:** Avaliação do tipo de documento exposto (projetos, contratos, dados de clientes) e determinação dos riscos associados.
- **Notificação ao setor jurídico e DPO:** Caso o documento contenha dados pessoais, o encarregado pelo tratamento de dados deve ser notificado, conforme obrigações da LGPD.
- **Revisão das políticas internas:** Verificação das políticas de uso de redes sociais e privacidade física no ambiente de trabalho.

Ações de contenção e prevenção:

- **Estabelecer zonas seguras:** Designação de áreas do escritório onde fotos são permitidas, com sinalização visível.
- **Implantação de *privacy screens* e bloqueio de monitores:** Redução da exposição de dados visuais em ambientes abertos.
- **Auditoria de postagens anteriores:** Verificação retroativa de outras publicações de colaboradores que possam conter exposições semelhantes.

7.2 Proposta de Treinamento de Conscientização em Segurança

Objetivo: Capacitar os colaboradores a identificar riscos relacionados à divulgação de informações visuais e promover uma cultura de proteção da informação.

Formato sugerido: Sessão presencial ou online, com duração de 1 hora, com reforços periódicos por e-mail e materiais visuais.

7.2.1 Conteúdo programático:

1. O que é engenharia social visual (Visual Hacking)?

- Exemplos reais de vazamentos por fotos, vídeos e chamadas de vídeo
- Estudos de caso (Snapchat, Zoom, redes sociais corporativas)

2. Boas práticas no ambiente de trabalho:

- Não fotografar áreas com papéis, quadros ou monitores visíveis
- Cuidado ao compartilhar imagens internas nas redes sociais
- Uso de filtros de privacidade e bloqueio automático de tela

3. Política de segurança da informação:

- Normas internas sobre compartilhamento de conteúdo
- Consequências para violações (advertências, sanções)

4. Atividade prática:

- Simulação com fotos contendo riscos ocultos (gamificação)
- Identificação de elementos sensíveis em imagens

7.2.2 Materiais de apoio:

- Cartilhas visuais com exemplos de boas e más práticas
- Cartazes de alerta para áreas comuns do escritório
- Política de uso de redes sociais revisada e distribuída digitalmente

8 Estudo de Caso: Construção de Perfil Digital de um Executivo com Fontes Abertas

A criação de um perfil digital detalhado a partir de fontes abertas (OSINT) é uma prática comum em auditorias de segurança e também uma técnica poderosa em ataques de engenharia social. O objetivo neste caso é levantar informações públicas sobre um executivo para identificar hábitos, rotinas e vulnerabilidades exploráveis.

8.1 Preparação e Definição de Objetivos

Antes de iniciar a coleta, é importante delimitar:

- **Quem é o alvo:** Nome completo, cargo, empresa onde trabalha.
- **O que será buscado:** Informações pessoais, profissionais, tecnológicas e comportamentais.
- **Qual a finalidade:** Avaliar riscos de segurança, riscos de engenharia social ou proteção de imagem.

8.2 Etapas da Investigação com Fontes Abertas

8.2.1 Coleta de dados pessoais e profissionais

- **Ferramentas:**
 - Google Dorks (`site:linkedin.com "Nome Completo"`)
 - Hunter.io, Emailrep.io (descoberta e reputação de e-mails)

- Have I Been Pwned (vazamentos associados ao e-mail)
- LinkedIn, ZoomInfo, RocketReach (carreira e histórico profissional)

- **Informações buscadas:**

- Cargo atual e passados
- Local de trabalho e cidade
- Equipes lideradas, áreas de atuação
- Contatos públicos, e-mails corporativos

8.2.2 Mapeamento de presença digital e redes sociais

- **Ferramentas:**

- Username Search, Namechk, WhatsMyName (para encontrar perfis em diversas redes)
- Pipl, Spokeo, Social Searcher (busca por pessoas)
- ExifTool, FotoForensics (metadados de fotos)

- **Informações levantadas:**

- Perfis em Instagram, Facebook, Twitter, YouTube, TikTok, Medium
- Fotos pessoais e familiares
- Localizações frequentes (check-ins, paisagens repetidas, placas)
- Hobbies, gostos, hábitos (esportes, restaurantes, viagens)

8.2.3 Rotinas e hábitos

- **Fontes de dados:**

- Postagens com timestamps
- Stories com locais identificáveis
- Padrões de publicações (ex: sempre na academia às 7h)

- **Ferramentas:**

- Creepy, GeoSpy, Google Maps + imagens públicas (geolocalização)
- InVID, YouTube Metadata (para análise de vídeos)

8.2.4 Dispositivos e aspectos técnicos

- **O que pode ser extraído:**

- Modelo de celular ou computador (através de fotos ou comentários)
- Sistemas e apps utilizados
- E-mails e domínios associados

- **Ferramentas:**

- theHarvester, Recon-ng, Maltego
- Shodan (caso o executivo utilize IoT ou serviços expostos)

8.3 Análise e Identificação de Vulnerabilidades

Pontos de atenção:

- **Exposição excessiva:** Publicações que revelam rotina, local de moradia, família.
- **Informações sensíveis em fotos:** Crachás, telas de notebook, documentos, placas de carro.
- **Relacionamentos:** Nome e perfis de cônjuges ou filhos (que podem ser vetores indiretos de engenharia social).
- **Vazamentos passados:** Contas com senhas vazadas que ainda podem estar ativas.
- **Possível uso de senhas fracas:** A partir de hobbies ou nomes de filhos/pets divulgados.

8.4 Considerações Éticas

Importante: Todo o processo deve respeitar os princípios éticos e legais do uso de fontes abertas, evitando qualquer forma de invasão, acesso indevido ou coleta de dados protegidos por sigilo.

9 Estudo de Caso: Exposição Técnica em Anúncios de Emprego Antigos

Durante uma auditoria OSINT, foi identificado que uma organização divulgava publicamente, em anúncios de emprego antigos, informações detalhadas sobre seu ambiente tecnológico. Esse tipo de exposição, muitas vezes negligenciado, representa uma importante superfície de ataque que pode ser explorada por agentes maliciosos.

9.1 Análise da Exposição Técnica

9.1.1 Exemplos comuns de informações expostas em anúncios

- **Tecnologias e stacks utilizados:**
 - Linguagens de programação (ex: Python, Java, C#)
 - Frameworks (ex: Django, Spring, Laravel)
 - Bancos de dados (ex: PostgreSQL, MongoDB, Oracle)
 - Ferramentas DevOps (ex: Jenkins, Docker, Kubernetes)
 - Sistemas operacionais (ex: Linux, Windows Server)
- **Modelos de infraestrutura:**
 - Uso de cloud computing (ex: AWS, Azure, GCP)
 - Ambientes híbridos ou on-premises
 - Políticas de backup, pipelines e versionamento
- **Ferramentas de segurança e monitoramento:**
 - SIEMs, firewalls, antivírus, ferramentas de pentest

9.1.2 Fontes utilizadas na auditoria

- **Sites de emprego:** LinkedIn, Glassdoor, Indeed, InfoJobs
- **Portais de tecnologia:** Vagas.com, GitHub (em repositórios da empresa), Stack Overflow Jobs
- **Arquivos em cache:** Wayback Machine, Google Cache

9.2 Riscos Associados à Exposição

9.2.1 Mapeamento de superfície de ataque facilitado

- Um atacante pode adaptar seus vetores com base em tecnologias conhecidas — por exemplo:
 - Procurar exploits recentes para frameworks específicos
 - Direcionar campanhas de phishing com base em ferramentas utilizadas internamente
 - Explorar configurações padrão ou portas abertas em aplicações conhecidas

9.2.2 Engenharia social mais eficaz

- Com conhecimento do stack, o atacante pode se passar por um fornecedor, prestador de serviço ou técnico do sistema — aumentando a credibilidade de um ataque.
- Também é possível produzir e-mails altamente personalizados, citando tecnologias reais da empresa (ex: “Atualização urgente do Jenkins”).

9.2.3 Reconhecimento técnico automatizado

- Ferramentas como o Recon-ng, theHarvester e scripts de Google Dorking podem ser usadas para identificar domínios e subdomínios que usam essas tecnologias, cruzando com outras informações públicas da empresa.

9.3 Medidas de Mitigação

9.3.1 Redação cuidadosa de vagas

- Utilizar descrições genéricas em vez de citar tecnologias específicas (ex: “frameworks modernos em Python”).
- Informar stacks apenas em entrevistas ou em ambientes controlados.

9.3.2 Revisão periódica de exposições passadas

- Auditorias retroativas em vagas antigas em caches e Wayback Machine.
- Solicitar exclusão de conteúdos antigos ou desatualizados de sites de terceiros.

9.3.3 Treinamento e sensibilização do RH e marketing

- Departamentos responsáveis por comunicação devem estar cientes dos riscos de exposição técnica involuntária.
- Conscientizar recrutadores sobre como suas descrições podem ser usadas para engenharia reversa do ambiente da empresa.

10 Estudo de caso: empresaXYZ.com

Este relatório apresenta uma análise detalhada do domínio **empresaXYZ.com** utilizando técnicas de coleta de informações públicas (OSINT) e identifica possíveis vetores para ataques de **engenharia social**. As fontes analisadas foram WHOIS, Shodan, Hunter.io e LinkedIn.

Dados Coletados

10.1 WHOIS

- **Registrante:** João da Silva (possivelmente um executivo da empresa)
- **Organização:** Empresa XYZ Ltda.
- **Endereço:** Rua Exemplo, 123 – São Paulo, SP, Brasil
- **Telefone:** +55 11 4002-8922
- **E-mail administrativo:** admin@empresaXYZ.com
- **Data de criação:** 15/03/2015
- **Última atualização:** 01/02/2024
- **Servidor DNS:** ns1.empresaXYZ.com, ns2.empresaXYZ.com

10.2 Shodan

- **Serviços Expostos:**
 - HTTP/HTTPS: Servidor web rodando Apache 2.4.52
 - FTP: Porta 21 aberta (potencial risco de login anônimo)
 - RDP: Porta 3389 identificada com banner do Windows Server
- **Localização do IP:** São Paulo, Brasil
- **Sistema Operacional:** Windows Server 2019
- **Certificados SSL:** Válidos até 30/11/2025 – em nome de empresaXYZ.com

10.3 Hunter.io

- **E-mails corporativos encontrados:**
 - joao.silva@empresaXYZ.com – CEO
 - maria.lima@empresaXYZ.com – RH
 - carlos.ti@empresaXYZ.com – Suporte Técnico
- **Formato dos e-mails:** nome.sobrenome@empresaXYZ.com
- **Verificados:** Sim, e-mails válidos

10.4 LinkedIn

- **Colaboradores Identificados:**
 - João Silva – CEO
 - Maria Lima – Gerente de Recursos Humanos
 - Carlos Oliveira – Analista de TI
 - Renata Souza – Analista de Marketing
- **Tecnologias mencionadas:**
 - Microsoft 365, Teams, SharePoint
 - Fortinet, AWS, SAP
- **Possíveis horários de atividade:** 08h às 18h (baseado em postagens e atualizações)

Análise de Vetores de Engenharia Social

10.5 Spear Phishing

- Utilização de nomes reais obtidos no LinkedIn e e-mails confirmados via Hunter.io.
- Alvos: **Maria Lima** (RH) e **Carlos Oliveira** (TI).
- Temas eficazes:
 - Atualização de currículo interno (RH)
 - Solicitação de suporte técnico falso (TI)

10.6 Pretexting (Pretexto)

- Disfarçar-se como fornecedor de tecnologia ou parceiro comercial.
- Criar cenários com base em tecnologias citadas (ex: suporte falso da Fortinet).

10.7 3. Vishing (Phishing por telefone)

- Usar o telefone do WHOIS para contatar o setor de TI fingindo ser do suporte da Microsoft.
- Induzir ao fornecimento de credenciais ou acesso remoto.

10.8 Baiting

- Envio de “currículos” ou “ofertas” contendo malware via e-mail.
- Explorar a rotina do RH e da área de marketing.

10.9 Watering Hole

- Identificar sites frequentemente acessados pela empresa (ex: blogs de marketing ou tecnologia).
- Injetar código malicioso nesses sites ou clonar páginas similares.

Conclusão

O domínio **empresaXYZ.com** possui várias exposições que podem ser exploradas em ataques de engenharia social. A coleta via OSINT revelou alvos específicos, estruturas de e-mail previsíveis, serviços expostos e uma cultura corporativa que pode ser imitada.

Recomendações:

- Utilizar WHOIS com privacidade.
- Minimizar serviços expostos sem autenticação forte.
- Treinamento contínuo em engenharia social para funcionários.
- Monitorar menções públicas da empresa e colaboradores.